

REPORTE EJECUTIVO DE GESTIÓN DE RIESGOS

Clínica Privada - Evaluación Inicial de Riesgos

1. Resumen ejecutivo

Se realizó una evaluación inicial de riesgos de seguridad de la información sobre una clínica privada de 120 empleados que atiende aproximadamente 800 pacientes por día y gestiona historias clínicas digitales, información de obras sociales y datos de facturación.

La valoración se realizó mediante una matriz de probabilidad e impacto de 1 a 5. Los resultados muestran que los riesgos relacionados con acceso no autorizado y ransomware requieren atención prioritaria debido a la combinación de una probabilidad elevada y consecuencias potencialmente críticas para la confidencialidad, integridad y disponibilidad de la información.

2. Top 5 de riesgos

Riesgo	Probabilidad	Impacto	Valor	Nivel
Acceso no autorizado a historias clínicas digitales	4	5	20	Crítico
Ransomware en sistemas clínicos	4	5	20	Crítico
Indisponibilidad del sistema de turnos e historias clínicas	3	5	15	Alto
Alteración indebida de información clínica	3	5	15	Alto
Filtración de datos de pacientes por error del personal	3	4	12	Alto

Los riesgos de mayor prioridad podrían afectar directamente la continuidad de la atención, la confidencialidad de los datos médicos y la confiabilidad de la información utilizada por los profesionales.

3. Estado de los planes de acción

Se definieron tres planes prioritarios de mitigación:

1. Implementación de MFA y revisión de accesos
 - Riesgo asociado: acceso no autorizado a historias clínicas.
 - Responsable: Martina López.
 - Vencimiento: 15/10/26.
 - Presupuesto estimado: USD 3.500.
 - Estado Inicial: No iniciado (0%).
2. Fortalecimiento de protección frente a ransomware
 - Riesgo asociado: ransomware en sistemas clínicos.
 - Responsable: Administrador de Seguridad.
 - Vencimiento: 05/11/2026.
 - Presupuesto estimado: USD 7.500.
 - Estado Inicial: No iniciado (0%).
3. Plan de alta disponibilidad para servicios asistenciales
 - Riesgo asociado: caída de infraestructura que soporta la atención de pacientes.
 - Responsable: Valentina Ríos.
 - Vencimiento: 05/12/2026
 - Presupuesto estimado: USD 6.500.
 - Estado inicial: No iniciado (0%).

4. Recomendaciones prioritarias

Se recomienda implementar autenticación multifactor para los accesos a sistemas que procesan información clínica y revisar periódicamente los privilegios asignados a cada perfil. Estas medidas deberían complementarse con capacitación frente a phishing y mecanismos de monitoreo que permitan detectar accesos anómalos.

También resulta prioritario fortalecer la protección de las estaciones de trabajo mediante tecnologías de detección y

respuesta, segmentar la red para limitar la propagación de incidentes y mantener copias de seguridad aisladas y verificadas mediante pruebas periódicas de restauración.

Para los servicios vinculados directamente con la atención de pacientes se recomienda incorporar redundancia, monitoreo de disponibilidad y procedimientos de contingencia que permitan continuar las operaciones esenciales ante una falla tecnológica.

Por último, los centros de datos y demás infraestructura tecnológica crítica no debería ubicarse junto a cocinas ni debajo de piletas, debido a la exposición innecesaria a riesgos de incendio e inundación respectivamente.

La aplicación progresiva de estas medidas permitirá disminuir la exposición de la organización, fortalecer la protección de la información clínica y mejorar la capacidad de respuesta y recuperación frente a incidentes.